

AI and Law I — Lecture Summary

Contents

1	Foundations: What is “law” and how to read it	2
1.1	Legal rules and how to read them	2
1.2	Legal fields and the EU context	2
2	Artificial intelligence: concepts and legal relevance	3
2.1	AI concepts and the AI Act definition	3
2.2	Why regulate AI (and what tends to go wrong)	3
3	Autonomous driving and liability: overview	4
3.1	Regulatory context and typical liability scenarios	4
3.2	Automation levels and the Austrian status quo (as presented)	4
4	Austrian tort law (ABGB): fault-based liability	4
4.1	Overview and liability tracks	4
4.2	Fault-based liability: what you must show	4
4.3	A few doctrinal/procedural points that come up often	5
5	Strict liability (Austria): motor vehicles / railways (EKHG)	5
5.1	Core regime: liability, claimants, and defences	5
6	EU product liability (Directive (EU) 2024/2853)	6
6.1	Framework and policy background	6
6.2	Product, defectiveness, and who can be liable	6
6.3	Damage, proof, defences, and limitation	7
7	Data protection law (GDPR)	7
7.1	Scope and key concepts	7
7.2	Principles and legal bases	8
7.3	Governance, security, and accountability duties	8
7.4	Rights of data subjects	9
8	Contracts in the digital age	9
8.1	Framework: regulation modalities and contract basics	9
8.2	Automation and smart contracting	9
8.3	Formation, interpretation, and consumer-law constraints	9
9	The EU AI Act: structure and core exam points	10
9.1	Purpose, scope, and actors	10
9.2	Risk model: prohibited and high-risk AI	10
9.3	High-risk requirements and obligations	11
9.4	Transparency and GPAI obligations	11
9.5	Penalties and enforcement (overview)	11

1 Foundations: What is “law” and how to read it

1.1 Legal rules and how to read them

In everyday life we follow many kinds of rules: moral rules, social norms, technical standards, and so on. **Law** is the subset of rules that is **created by the state** and backed by public authority. What matters for exams is the basic “why law is special” idea:

- Legal rules **can be enforced** (courts/authorities can compel compliance or impose sanctions).
- They are made through **formal procedures** (e.g. legislation), not just informal agreement.
- They are generally **binding** even if they feel unfair or are often ignored in practice.
- They should be **sufficiently clear and predictable** (**legal certainty** / determinacy).

At EU level you will mostly encounter two forms of legislation:

- **Regulations**: apply directly in Member States without national implementing acts.
- **Directives**: set goals that Member States must implement in national law.

When reading a statute, you mainly need the basic “address system” for citations (you do *not* need to memorise many paragraph numbers for the exam, but you should be able to follow a reference):

- **Section/Paragraph** (German: **Paragraph**) and sub-units such as **Absatz** (paragraph/para) and **Ziffer** (number).
- Rules can be **alternative** (“A or B is enough”) or **cumulative** (“A and B are required”).

1.2 Legal fields and the EU context

A useful first distinction is between **public law** and **private law**:

- **Public law** governs relations between the **state** and individuals. A core idea (especially in Austria) is the **principle of legality**: public authorities need a legal basis for what they do.
- **Private law** governs relations between **private parties**. Even here, claims (e.g. damages, payment) still need a legal basis (typically in civil codes like the Austrian *ABGB*).
- In real life the two overlap: for example, a private contract can become ineffective because a public-law restriction makes performance unlawful.

In Austrian civil law it is helpful to remember the “style” of the system:

- It is largely **codified**: core rules are in statutes/codes (e.g. *ABGB*).
- Case law guides interpretation, but decisions are generally **not formally binding** for future cases in the same way as in common-law systems.

For EU law, two ideas show up often:

- **EU competences**: some areas are **exclusive** (only the EU may legislate), others are **shared** (EU and Member States; Member States act where the EU has not acted), and some are supporting/coordination competences.
- **Private international law** (conflict-of-laws) answers a different question than “what is the rule?”: it decides *which country’s law applies* in cross-border disputes. In the EU this is largely done through the “Rome” regulations:
 - **Rome I** (Reg. (EC) 593/2008): selects the applicable law for **contracts**.
 - **Rome II** (Reg. (EC) 864/2007): selects the applicable law for **non-contractual liability/torts**.

Constitutional anchors (Austria) Two public-law principles repeatedly show up in the lecture examples:

- **Legality principle:** public authorities may act *only on the basis of law*.
- **Equality / non-discrimination:** like cases must be treated alike unless there is an objective justification.

2 Artificial intelligence: concepts and legal relevance

2.1 AI concepts and the AI Act definition

AI is not one single technique. Historically it covers many approaches (symbolic methods, statistics, machine learning, neural networks). For law, what matters is how the **EU AI Act** defines its scope.

The AI Act uses a broad definition:

Under the **EU AI Act**, an **AI system** is “*a machine-based system that is designed to operate with varying levels of autonomy and that may exhibit adaptiveness after deployment, and that, for explicit or implicit objectives, infers, from the input it receives, how to generate outputs such as predictions, content, recommendations, or decisions that can influence physical or virtual environments*”.

In practice, you check a few recurring elements to decide whether something fits:

- It pursues an **explicit or implicit objective**.
- It **infers outputs** from inputs (e.g. predictions, recommendations, decisions).
- It has some **autonomy** (it does not require constant human intervention).
- It *may* be **adaptive** after deployment (it can change/learn).
- Its outputs can **influence** a physical or virtual environment.

2.2 Why regulate AI (and what tends to go wrong)

Regulation is motivated by two big clusters of concerns:

- **Safety:** physical harm, accidents, property damage.
- **Fundamental rights:** discrimination/equal treatment, freedom of expression, privacy and data protection.

Two technical limitations matter legally because they affect accountability and review:

- **Bias:** outcomes depend on data and feedback loops; biased data can produce systematically unfair results.
- **“Black box” behaviour:** limited explainability can undermine transparency, judicial review, and procedural safeguards.

When the state uses automated decision-making, two classic public-law principles are worth remembering (as presented in the course, Austria as illustration):

- **Equal treatment / non-discrimination:** state action must not create unjustified privileges or discrimination (especially on protected grounds).
- **Legality:** authorities may only impose requirements that have a basis in law; “adding extra conditions” without legal basis violates the legality principle.

3 Autonomous driving and liability: overview

3.1 Regulatory context and typical liability scenarios

Autonomous driving sits between traffic regulation (who may drive, under what conditions) and liability law (who pays when something goes wrong).

- International background: the **Vienna Convention on Road Traffic (1968)** traditionally assumes a human **driver**. Modern approaches try to accommodate automated systems, but only if national law and operating rules allow it.
- EU vehicle rules: **type-approval** and safety requirements are shaped by instruments such as **Regulation (EU) 2019/2144** (“General Safety Regulation”), including requirements like driver availability monitoring, event data recorders, and safety-related information flows.
- National law still matters a lot (e.g. whether and how Level 3/4 operation is permitted).

3.2 Automation levels and the Austrian status quo (as presented)

- **SAE levels** (exam intuition): Level 3 = conditional automation with a *human fallback*; Level 4 = high automation within an operational design domain (ODD); Level 5 = full automation.
- **Austria (illustrative)**: widespread operation of automated driving on public roads is not the baseline; the course highlights mainly **testing/controlled use**, with a strong emphasis that a human must be able to **take over** when requested (linked in the slides to §102 Abs. 3a, 3b KFG and the *AutomatFahrV*).
- **EU-wide use is constrained**: even if a type-approval exists at higher automation, the lecture stresses that **local/limited ODD use** does not automatically mean “allowed everywhere in Europe”.

From a liability perspective, the recurring fact patterns are simple:

- A technical failure (software or hardware malfunction).
- Human mishandling or insufficient supervision (driver fault) and/or organisational failures (keeper negligence).
- Typical harms are personal injury and property damage.

4 Austrian tort law (ABGB): fault-based liability

4.1 Overview and liability tracks

The starting point in Austrian private law is sometimes summarised as “**casum sentit dominum**”: if you suffer damage, you normally bear it yourself. You can shift the loss to someone else only if the legal requirements for liability are met.

In practice, Austrian law uses two main “tracks”:

- **Fault-based liability** under the Austrian General Civil Code (*ABGB*).
- **Strict liability** in special statutes for typical dangers, e.g. the *EKHG* (railways/motor vehicles) and the *PHG* (product liability, aligned with EU rules).

4.2 Fault-based liability: what you must show

For a typical damages claim under the *ABGB*, you usually need four building blocks:

1. **Damage** that the law recognises as compensable,

2. **Causation** (the defendant's conduct contributed to the harm),
3. **Wrongfulness** (a legal duty/right was violated),
4. **Fault** (intent or negligence).

(1) **Damage.** The core split is between material and immaterial harm:

- **Pecuniary/material damage** is generally compensable (e.g. personal injury costs, property damage).
- **Lost profit** is usually excluded, but can be available in specific situations (as presented in the course, e.g. gross negligence or certain B2B contexts).
- **Immaterial damage** is generally not compensated unless the law expressly provides it (e.g. pain and suffering).

(2) **Causation.** A standard test is **conditio sine qua non**: would the damage have occurred *without* the defendant's action/omission?

(3) **Wrongfulness.** Wrongfulness can arise in several typical ways:

- breach of a contract,
- infringement of **protected rights** (physical integrity, freedom, property, reputation),
- violation of a **protective statute** (a rule specifically aimed at preventing damage, e.g. traffic safety rules),
- breach of duties to control risks one has created.

(4) **Fault.** Fault ranges from **intent** to **gross** and **slight negligence**. It also presupposes that the person is capable of being at fault (age/capacity; legal entities act through their organs).

4.3 A few doctrinal/procedural points that come up often

For exams, the logic is more important than paragraph citations:

- **Burden of proof:** as a rule, the claimant must prove the facts supporting the claim (including fault). In contractual settings, Austrian law can shift the burden regarding fault (often discussed with reference to §1298 ABGB).
- **Tort vs. contract:** the ABGB follows a “single-rule” approach—fault-based liability can arise whether the source is a contract breach or a non-contractual wrong (often associated with §1295 ABGB).
- **Liability for auxiliaries:** in contracts, you typically answer for your auxiliary's fault towards your counterparty (often discussed via §1313a ABGB). Towards third parties in tort, liability for servants is narrower (often linked to §1315 ABGB).
- **Limitation:** many claims prescribe after 3 years from knowledge of damage and damaging party, with longer long-stop periods in some cases (often referenced via §1489 ABGB).

5 Strict liability (Austria): motor vehicles / railways (EKHG)

5.1 Core regime: liability, claimants, and defences

Strict liability exists because operating certain sources of danger (like vehicles) creates risks even without misconduct. Under the EKHG, liability is therefore *not* tied to fault.

- The law focuses on an **accident**: a sudden event causing damage.
- Typical claimants are the injured person and owners of damaged property.
- The main liable person is the **keeper** (the person who operates the vehicle for their own account and has control over its use; not necessarily the owner). Depending on the case, the driver can also be liable under fault rules.
- Liability insurance is compulsory; EU motor insurance rules harmonise key aspects.

A key defence is the **inevitable event**: no liability if the accident was unavoidable even under the highest standard of care and there was no relevant defect of the vehicle (including software).

6 EU product liability (Directive (EU) 2024/2853)

6.1 Framework and policy background

EU product liability is **strict liability**: the claimant does not have to prove fault. Directive (EU) 2024/2853 is a **full harmonisation** instrument, meaning Member States cannot introduce higher/lower protection in the harmonised field.

- Basic idea: if a **defective product** causes damage, the injured person has a right to compensation.
- Liability is mandatory: producers cannot simply contract it away.

The course also links this to the Commission’s broader “AI and liability” initiative:

- **AI Liability Directive** (proposal): aims to make fault-based claims involving AI easier by addressing proof problems (especially causation and burden of proof).
- **Revised Product Liability Directive**: the strict-liability arm of the package, now adopted as Directive (EU) 2024/2853.

This liability package is separate from road-traffic type-approval/safety regulation.

- **Implementation deadline**: Member States must update national law to the new directive by **9 December 2026**.
- **Who else can be liable**: beyond classic manufacturers/importers, the slides mention **online platform providers** in certain “distance sale” constellations if no other EU economic operator can be identified.

Contributory fault. Even under strict product liability, **contributory fault** by the injured person can reduce or (in extreme cases) eliminate compensation.

6.2 Product, defectiveness, and who can be liable

A **product** is defined broadly and includes moveables, electricity, digital manufacturing files, and **software** (even if integrated into other products).

A product is **defective** if it does *not* provide the level of safety the public is entitled to expect. The assessment is contextual: presentation/instructions, reasonably foreseeable use, connectivity effects, post-market learning/new features, time of placing on the market, cybersecurity-related safety requirements, recall measures, and the needs of the intended user group can all matter. Importantly, a product is not “defective” *just because* a better version exists later.

Liability can attach to several actors in the supply chain (depending on the case): manufacturer (including component manufacturer in some cases), importer, authorised representative, fulfilment service provider, distributor (subsidiary, if no other EU operator is identifiable), and also a party that **substantially modifies** the product and then places it on the market/puts it into service.

6.3 Damage, proof, defences, and limitation

The directive distinguishes what counts as compensable damage:

- **Personal injury** is compensated in full.
- **Property damage** covers damage to tangible goods other than the defective product itself (including a product damaged by a defective component integrated under the manufacturer's control).
- **Pure economic loss** ("pure nominal loss", like mere loss of use) is not covered unless it materialises as personal injury or property damage.

On proof, the baseline remains: the claimant proves defect, damage, and causal link. However, courts must be able to order **disclosure of evidence** from defendants when the claim is made plausible, and the directive provides **rebuttable presumptions** in typical situations (e.g. non-disclosure, breach of safety requirements, obvious malfunction, or technical complexity making proof excessively difficult).

There are also recognised **defences** (illustrative): the product was not placed on the market by the defendant; the defect did not exist at that time; the defect stems from compliance with mandatory rules; development risks (state of scientific/technical knowledge could not detect the defect); and specific component/modification defences.

Limitation is typically: 3 years from knowledge of damage/defect/producer identity, plus a long-stop period of 10 years from placing the product into circulation.

7 Data protection law (GDPR)

7.1 Scope and key concepts

The main instrument is the **GDPR** (Regulation (EU) 2016/679), applicable since 25.05.2018 (replacing Directive 95/46/EC). It is technology-neutral and often works with "state of the art" and risk-based concepts.

If the GDPR is violated, the consequences are mainly:

- supervisory authorities can order compliance and restrict/ban processing;
- administrative fines can reach **EUR 10 million/2%** or **EUR 20 million/4%** of worldwide annual turnover (depending on the type of violation);
- individuals can claim **compensation** for material or non-material damage.

The GDPR's reach is broad:

- **Material scope**: it covers processing of personal data, whether automated or (if organised in a filing system) non-automated.
- **Territorial scope**: it applies to EU establishments even if processing happens elsewhere, and it can apply to non-EU actors if they offer goods/services to people in the EU or monitor behaviour in the EU.

Personal data.

"Personal data" means any information relating to an identified or identifiable natural person (the "data subject"). Identification can be direct or indirect (e.g. name, ID number, location data, online identifier, or factors specific to physical/physiological/genetic/mental/economic/cultural/social identity).

Special categories. Some data are treated as **sensitive** (“special categories”), including racial/ethnic origin, political opinions, religious/philosophical beliefs, trade union membership, genetic/biometric data for unique identification, health data, and data about sex life/sexual orientation.

Exclusions. Truly **anonymised** data fall outside the GDPR; the GDPR covers living natural persons (not the deceased), and it does not as such protect legal persons (though information about employees/managers is still personal data).

Processing.

“Processing” covers almost anything you can do with personal data: collecting, storing, changing, using, disclosing, combining, restricting, erasing, etc. (automated or not).

Controller vs. processor. The **controller** decides the purposes and means; the **processor** processes on the controller’s behalf. Their relationship is typically governed by a GDPR processing agreement (instructions, confidentiality, security measures, assistance duties, deletion/return, audit rights).

7.2 Principles and legal bases

GDPR compliance starts with principles: lawfulness, fairness, transparency; purpose limitation; data minimisation; accuracy; storage limitation; integrity/confidentiality; and **accountability** (the controller must be able to demonstrate compliance).

Processing needs a legal basis:

- For ordinary personal data (GDPR): consent; contract; legal obligation; vital interests; public task/official authority; legitimate interests.
- For special categories: a narrower list of exceptions applies (e.g. explicit consent, employment/social protection contexts, vital interests, legal claims, substantial public interest, health/public health, research/statistics/archiving with safeguards).

7.3 Governance, security, and accountability duties

A few duties are particularly exam-relevant because they show how GDPR turns principles into organisational practice:

- **Data Protection Officer (DPO):** required in certain cases (notably large-scale systematic monitoring or large-scale sensitive data processing). The DPO must be independent, qualified, supported by management, and acts as contact point for the authority and data subjects.
- **International transfers:** outside the EU/EEA, transfers need a legal “bridge” (e.g. an adequacy decision, standard contractual clauses, or a narrow derogation such as explicit consent).
- **DPIA** (impact assessment): required *before* processing when new technologies create a likely high risk for rights and freedoms.
- **Privacy by design/default:** build compliance into systems and minimise data by default.
- **Security measures:** implement risk-appropriate technical and organisational measures (e.g. encryption, pseudonymisation, resilience, recovery, and regular testing).
- **Documentation and transparency:** keep records of processing activities and provide clear information to data subjects (privacy notices under Arts. 13–14 GDPR).

7.4 Rights of data subjects

Data subjects have rights that structure how organisations must behave: access, rectification, erasure, restriction, portability, and objection. A special point for automated systems is the GDPR’s protection against being subject to **solely automated decision-making** with legal or similarly significant effects, unless an exception applies (e.g. contract necessity, legal authorisation, explicit consent) and safeguards are in place.

8 Contracts in the digital age

8.1 Framework: regulation modalities and contract basics

The course uses Lessig’s idea that behaviour is shaped by four modalities: **law**, **social norms**, **market**, and **architecture** (technology). In digital contexts, **architecture** becomes especially powerful: systems can “enforce” behaviour by design.

A standard working definition is:

A **contract** is a set of promises between parties to act (or refrain from acting) in certain ways, and the law provides remedies if those promises are broken.

In Austrian contract law, most contracts are **form-free**: offer and acceptance can be expressed orally (e.g. phone), in writing (paper, e-mail), or by conduct (e.g. clicking an “order” button). Only specific contract types require a special form (e.g. written/notarial form).

Contract law as such is not fully harmonised in the EU (formation, validity, remedies), but the EU harmonises many **sector rules** (especially consumer law, e-commerce, and digital content).

8.2 Automation and smart contracting

The key conceptual distinction is:

- **Automated contracts**: the system applies pre-set rules under user control.
- **Autonomous contracts**: the system can change behaviour in ways the owner cannot fully anticipate.

“Contracting by design” can happen at different stages: auto-formation (system concludes contracts), auto-execution (system performs), and auto-enforcement (system enforces through technical measures). A well-known technical definition is:

Smart contract (Szabo): *“a computerised transaction algorithm that performs the terms of the contract”.*

8.3 Formation, interpretation, and consumer-law constraints

Even in digital settings, contract formation relies on the familiar offer/acceptance structure (words or conduct showing intent to be bound). The course uses the **CISG** (UN Sales Convention) as illustration: offers must be sufficiently definite and intended to be binding; silence is generally not acceptance; and modified acceptances can operate as counter-offers.

Interpretation (why code does not replace law). Even if performance is automated, the **legal** meaning of a contract is interpreted using ordinary interpretation tools:

- If both parties shared a specific understanding, that understanding governs.
- Otherwise, the benchmark is how a **reasonable person** in the other party’s position would understand the statement/conduct (CISG-style intuition used in the lecture).

This is one reason why “code = contract” is risky: code may execute, but courts still interpret *intent* and *legal validity*.

Automation introduces practical legal questions: can parties delegate assent to a machine, do code-based terms need translation into plain language, how do we interpret intent, and who bears the consequences of unexpected behaviour by learning agents?

Where consumers are involved, EU consumer law adds hard constraints (mainly through the **Consumer Rights Directive** and the **Unfair Contract Terms Directive**):

- Before consumers are bound, traders must provide clear pre-contractual information (identity, price, withdrawal rights, delivery/payment conditions, etc.). For “order with obligation to pay” flows, the consumer must explicitly acknowledge the payment obligation.
- Consumers typically have a **14-day withdrawal right** for distance/off-premises contracts, which implies practical “unwinding” mechanisms even when execution is automated/immutable.
- Unfair terms control focuses on transparency and substantive unfairness; unclear terms are read in the consumer’s favour, and terms that undermine remedies or access to legal action can be invalid.

Finally, “auto-enforcement” must not bypass mandatory rights:

- Auto-execution is only sensible if the underlying agreement is valid/lawful and consumers can still exercise mandatory rights (especially withdrawal).
- Even in irreversible systems, the *contract* can be void/voidable (capacity, mistake, fraud, duress, unlawfulness) and execution can deviate from intent (coding errors). Practical reversibility is therefore crucial (off-chain remedies, reverse transactions, etc.).
- Self-help enforcement raises legality issues and may conflict with fundamental/procedural rights (right to be heard, fair trial) and safety concerns (risk of physical harm if devices are disabled).

9 The EU AI Act: structure and core exam points

9.1 Purpose, scope, and actors

The **EU AI Act** sets a uniform framework for placing AI systems on the market, putting them into service, and using them in the EU. Its headline idea is **risk-based regulation**: the stricter the risk for health, safety, and fundamental rights, the heavier the obligations.

- It prohibits certain **unacceptable** practices outright.
- It imposes detailed requirements for **high-risk** AI.
- It adds transparency duties for some **limited-risk** systems.

The Act applies broadly across sectors, with exceptions (e.g. private use, national security/military, some R&D contexts). It can also apply to non-EU providers if outputs are used in the EU.

Actors are defined functionally along the value chain: **provider** (puts on market/into service), **deployer** (uses under authority), **importer**, **distributor**, and **authorised representative**.

9.2 Risk model: prohibited and high-risk AI

The Act uses a four-level vocabulary (as presented in the course): unacceptable risk (prohibited), high risk (regulated heavily), limited risk (transparency), and low risk (largely free).

Examples of **prohibited** practices (selected): social scoring; exploitation of vulnerabilities or subliminal manipulation; certain biometric categorisation; emotion recognition in workplace/education; untargeted facial-image scraping; broad real-time remote biometric identification in public spaces

(only narrow law-enforcement exceptions); predictive policing; and systems inferring sensitive traits like political views or sex life.

A system is **high-risk** mainly in two ways:

- It is (or is part of) a safety-regulated product area listed in **Annex I** (e.g. medical devices) and subject to product conformity assessment; or
- It is used in a sensitive domain listed in **Annex III** (critical infrastructure, education, employment, essential services, law enforcement/justice, border control, etc.), unless an exclusion applies because it has no significant risk/impact.

9.3 High-risk requirements and obligations

High-risk AI must meet a bundle of organisational and technical requirements: risk management, data governance, technical documentation, logging, transparency/instructions, human oversight, and robustness/cybersecurity.

Responsibilities depend on the actor:

- **Providers** run quality management, ensure conformity assessment before market placement, keep documentation/logs, cooperate with authorities, and apply CE marking/corrective measures.
- **Distributors** check CE/documentation, ensure storage/transport does not compromise compliance, and cooperate with authorities.
- **Deployers** use systems as instructed, ensure human oversight and appropriate input data, monitor performance, and notify providers/authorities if serious risks arise; workplace deployments trigger information duties to workers/representatives.

A “quasi-provider” rule applies: if an actor rebrands, substantially modifies, or repurposes a high-risk system so it remains/becomes high-risk, they may take on provider obligations.

9.4 Transparency and GPAI obligations

Some AI must be transparent to users: chatbots (tell users they interact with AI unless obvious), deepfakes (disclosure), and certain AI-generated public-facing content (disclosure, with exceptions). Generative systems must support marking outputs as artificially generated/manipulated in machine-readable form, subject to exceptions discussed in the course.

The Act also regulates **general-purpose AI (GPAI) models**. All GPAI models have baseline transparency and documentation duties for downstream integrators and, on request, authorities. **Systemic-risk** GPAI models have additional obligations (risk assessment/mitigation, evaluations, cybersecurity, incident reporting, and energy-use information), with an open-source carve-out mentioned in the slides when no systemic risk is present.

9.5 Penalties and enforcement (overview)

Member States must provide effective and dissuasive penalties. The slides summarise a tiered fine structure:

- up to EUR 35 million or 7% of worldwide turnover for violating prohibited practices;
- up to EUR 15 million or 3% for non-compliance with key requirements/obligations;
- up to EUR 7.5 million or 1.5% for supplying false/incomplete/misleading information to notified bodies.